PENSE-BÊTE · RECOMMANDATIONS DE SÉCURITÉ

Référentiel Général de Sécurité 2.0

02-40 RGS 2.0 - Référentiel national Sécurité — source : fiche de révision du module (gemma4, 03/11/2026 ; relu par Claude le 04/11/2026)

À RETENIR

1. La mise en conformité suit un processus en 5 étapes incluant l'analyse des risques et l'homologation.
2. Les fonctions cryptographiques comme la signature ou le cachet s'appuient sur trois niveaux de sécurité.
3. L'homologation est une décision formelle de l'autorité administrative qui accepte les risques résiduels.

Démarche de mise en conformité

Notion	À retenir
Processus standard	Démarche en **5 étapes** imposée par le **décret RGS** : 1. **analyse des risques**, 2. **objectifs de sécurité**, 3. **mesures de protection/défense**, 4. **homologation**, 5. **suivi opérationnel**.
Processus simplifié	Pour **systèmes déjà en service** : 1. **audit de sécurité** (interne/externalisé), 2. **analyse de risques simplifiée** + **mesures correctives**, 3. **décision d'homologation** + **suivi opérationnel classique**.
Facteurs de succès	Intégration de **clauses de sécurité** dans les **contrats prestataires** et importance du **facteur humain** (**sensibilisation** et **formation** du personnel).

Étapes techniques de la sécurité

Notion	À retenir
Analyse des risques	Précise les besoins selon les menaces/enjeux. Décide des usages cryptographiques et des **3 niveaux** de sécurité. Méthode : **ISO 27005** et **EBIOS**.
Objectifs de sécurité	Couvrent **disponibilité**, **intégrité**, **confidentialité**, plus **authentification** et **traçabilité** (RGS). Doivent être formulés en termes de **protection** et de **défense**.
Homologation de sécurité	Attestation formelle de l'**autorité administrative responsable**. Confirme l'acceptation des **risques résiduels**. S'appuie sur un **dossier d'homologation** et nécessite des **revues périodiques**.
Suivi opérationnel	Collecte/analyse des **journaux d'événements** et **alarmes**. Inclut **gestion des incidents**, **veille sur les vulnérabilités** et mise à jour des **plans de continuité**.

Protection des échanges et cryptographie

Notion	À retenir
Principes généraux	Le RGS fixe des **exigences de fonctions** et de **niveaux de sécurité** sans imposer de technologie spécifique. Voir **annexes B1, B2 et B3**.
Certificats électroniques	Utilisés pour **authentification**, **signature**, **cachet** et **confidentialité**. Trois niveaux : **1 étoile**, **2 étoiles** et **3 étoiles**. Double usage (authentification/signature) limité aux niveaux **1** et **2 étoiles**.
Authentification	Vérifie l'identité d'une **personne** ou d'une **machine**. Repose sur : **bi-clé**, **certificat**, **dispositif d'authentification** et **module de vérification**.
Signature et cachet	Signature : **identité**, **intégrité** et **consentement**. Cachet : **intégrité** et **origine** (serveurs/services). Niveau **3 étoiles** avec **dispositif sécurisé** = présumée fiable (**code civil**).
Confidentialité	Repose sur le **chiffrement** et la **gestion des droits d'accès** (doit être implémentée au plus près du **stockage des données**).
Horodatage électronique	Atteste l'existence d'une donnée via une **contremarque de temps**. Niveau de sécurité **unique** (**annexe A5**). Conforme au **décret de 2011** = conforme au **RGS**.

Accusés et qualifications

Notion	À retenir
Accusés d'enregistrement et de réception	Recommandés **horodatés** et **signés** ou **cachetés** selon les niveaux du RGS. Sauvegarde **obligatoire** tant que des réclamations sont possibles.
Qualification des produits de sécurité	L'autorité administrative doit privilégier les produits qualifiés. Trois niveaux : **élémentaire**, **standard** et **renforcé**. Repose sur **certification préalable** (**CSPN** ou **Critères Communs**) + contrôles par l'**ANSSI**.
Qualification des prestataires de services de confiance	Accordée pour **3 ans**. Concerne : prestataires de **certification électronique**, d'**horodatage** et d'**audit**. Auditeurs évalués sur : **audit organisationnel**, **de code**, **d'architecture** et **tests d'intrusion**.

Validation, organisation et transition

Notion	À retenir
Validation certificats	Dossier (**Politique de Certification** + **audit de conformité**) envoyé à l'**ANSSI**. Silence de **deux mois** vaut validation. Racines **IGC/A** garantissent la confiance.
Recommandations organisationnelles	Responsabilités via **RSSI** et **PSSI**. Sécurité intégrée dès le début des projets. Plans de **continuité** et de **reprise d'activité** testés régulièrement.
Recommandations externalisation	Projets **nuage** : analyse des risques spécifiques requise. Contrats : inclure clauses de **réversibilité** et de **propriété des données**.
Transition V1/V2	Nouveaux systèmes : application immédiate de la **V2**. Certificats **V1** émissibles pendant **un an**. Acceptés durant leur durée de vie (**transition totale max 4 ans**).

Pièges et confusions

- ⚠ Déléguer la responsabilité de l'homologation à un tiers
- ⚠ Confondre la signature pour les personnes physiques avec le cachet pour les machines
- ⚠ Attribuer trois niveaux de sécurité à l'horodatage
- ⚠ Utiliser un certificat à double usage au niveau de sécurité trois étoiles
- ⚠ Penser que la validation des certificats par l'Etat porte sur le statut technique de révocation

Sigles et définitions

RGS	Cadre réglementaire visant à renforcer la confiance des usagers dans les services électroniques
Analyse de risques	Démarche d'identification des menaces et décision d'actions pour réduire le risque
Homologation de sécurité	Décision formelle attestant que le système est protégé et les risques résiduels acceptés
Signature électronique	Mécanisme garantissant l'identité, l'intégrité et le consentement du signataire
Cachet électronique	Équivalent de la signature pour un service applicatif ou une machine
Horodatage électronique	Fonction attestant l'existence d'une donnée à un instant donné via une contremarque de temps
IGC/A	Infrastructure de Gestion de la Confiance de l'Administration dont l'ANSSI est l'autorité racine
PSCO	Prestataire de Services de Confiance Qualifié

Auto-test

1. Quelles sont les méthodes d'analyse des risques mentionnées ?
2. Quels sont les trois niveaux de qualification des produits de sécurité ?
3. Quelle est la durée de validité d'une qualification de prestataire ?
4. Que signifie le silence de deux mois lors de l'envoi du dossier à l'ANSSI ?
5. Quels sont les deux types de processus de mise en conformité ?

Réponses : **1.** ISO 27005 et EBIOS · **2.** Élémentaire, standard et renforcé · **3.** 3 ans · **4.** Validation · **5.** Processus standard et processus simplifié

À compléter par la fiche, le podcast et le quiz du module. Rédigé à partir de la fiche de révision ; seuils et chiffres à la date de la source.